Alder Quay Financial Services Ltd

UK GDPR and Data Protection Manual

FICTIONAL TRAINING / TEST DOCUMENT - NOT LEGAL ADVICE

Alder Quay Financial Services Ltd is invented. All staff, systems, limits, approvals and company arrangements in this pack are synthetic. No real authorisation, regulatory registration, employment entitlement or product is represented. Use only to test document retrieval and grounded answers.

Document Id: AQ-CMP-003

Version: 2.2

Effective Date: 2026-10-01

Review Date: 2027-10-01

Status: Current - synthetic

Classification: Internal - synthetic test data

Owner: Data Protection Officer

Approver: Fictional Board Policy Committee

Related documents: AQ-HR-001, AQ-CMP-001, AQ-CMP-002, AQ-CMP-004

Contents and citation guide

1. Scope and legal context

2. Lawful processing and transparency

3. Rights requests and data sharing

4. Personal data breach assessment

5. Synthetic retention schedule and holds

6. Accountability, scenario and source

Cite document ID, version and section number. All versions in this pack are current as of the shared effective date. Change notes refer to fictional history; superseded documents are not supplied.

1. Scope and legal context

This fictional manual describes internal privacy controls, not a complete statement of UK GDPR, the Data Protection Act 2018 or subsequent amendments, including the Data (Use and Access) Act 2025 and its commencement arrangements. The DPO checks current law and ICO guidance before real decisions

Controller, processor and joint-controller roles are assessed per processing activity, not assumed from a supplier label. All pack examples are synthetic.

2. Lawful processing and transparency

Record purpose, data categories, recipients, lawful basis, retention and responsible owner in the processing register before starting a new activity. Do not default to consent for all employee or customer processing. Special-category and criminal offence data require additional conditions and safeguards assessed by the DPO

Provide appropriate privacy information, minimise collection and restrict access by need. New monitoring, profiling, AI or large-scale sensitive-data processing requires DPO screening for a data protection impact assessment before procurement or deployment. Obtain approval before materially changing a purpose.

3. Rights requests and data sharing

Send any access, correction, erasure, objection or other rights request to the DPO on the day received, regardless of channel or whether legal terminology is used. The DPO confirms identity proportionately, logs receipt, assesses scope, exemptions and applicable response timing under current law. The internal triage target is two working days; it is not the legal response deadline

Never promise deletion when a legal hold or valid retention basis applies. Supplier contracts must address instructions, security, incidents, sub-processors, rights assistance and exit. Overseas access requires a transfer assessment; approval under AQ-HR-004 alone does not establish a valid transfer mechanism.

4. Personal data breach assessment

Employees report possible breaches immediately under AQ-CMP-002 section 5. The DPO records awareness time, categories, affected people, likely consequences, containment and notification rationale. ICO guidance describes notification of notifiable UK GDPR breaches without undue delay and, where feasible, within 72 hours of awareness; the risk threshold and applicable regime must be assessed, and not every breach requires ICO notification

High-risk cases may also require communication to affected people without undue delay. Document decisions even when not reporting. If details are incomplete, assess phased reporting rather than waiting for a full investigation. Check current guidance and any relevant amendments before acting.

5. Synthetic retention schedule and holds

The following are fictional company retention defaults, not universal legal minima: employee core personnel files - six years after employment ends; detailed sickness and medical support records - three years after the case closes; approved expense claims - seven years after the financial year ends; client advice and suitability files - seven years after the relationship ends; security event logs - 12 months from event; internal audit workpapers - seven years after final report; declined prospect enquiries - 12 months after last contact. The DPO and Legal validate necessity, product-specific obligations and exceptions

Legal or regulatory holds suspend scheduled deletion for relevant records only. Owners review expired records monthly and record secure deletion; backups expire through the approved cycle, with held data separately preserved.

6. Accountability, scenario and source

The DPO reviews the processing register quarterly and reports unresolved risks to the Risk Committee. Training is required on joining and annually. A misdirected client statement is a potential breach even if the recipient says they deleted it; record and assess it

A chatbot must not infer that the internal two-working-day triage target allows delay in breach escalation. Official context checked 18 October 2026: ICO, Personal data breaches: a guide, https://ico.org.uk/for-organisations/report-a-breach/personal-data-breach/personal-data-breaches-a-guide/ . This source supports breach context only, not every control in this manual. Version 2.2 distinguishes company targets from external notification rules.